

Security Incident Response Runbook

Purpose: This runbook explains how the response team handles suspicious access, data export, malware, and service compromise events. The runbook is designed for security analysts, IT operations, legal, privacy, and business system owners.

Initial triage: The first responder must verify the alert, identify the affected identity or system, record the timeline, and preserve volatile evidence. The analyst should not delete suspicious files, disable logging, or overwrite audit data. If the activity is ongoing, the analyst may isolate the endpoint or suspend the account after collecting enough information to support containment.

Severity model: Severity 1 is used for confirmed data exfiltration, production system compromise, ransomware, or active attacker control. Severity 2 is used for suspicious privileged access, likely data exposure, malware on a managed device, or repeated failed containment. Severity 3 is used for isolated suspicious activity with no evidence of data exposure or privilege escalation.

Suspicious login procedure: Confirm the source IP address, device, location, authentication method, conditional access result, and recent password or MFA changes. The team should reset credentials, revoke sessions, require MFA re-registration, and review access to sensitive applications. If finance, HR, customer, or regulated systems were accessed, notify the data owner and privacy lead.

Data export procedure: Preserve audit logs, export job details, file names, destination IP addresses, storage bucket names, and user session records. Compare the export volume with normal business activity. If customer, employee, financial, or regulated data may have left the environment, classify the incident as at least Severity 2 and escalate to privacy and legal teams.

Evidence handling: Evidence must be stored in the incident case folder with read-only access. Required evidence includes alert details, logs, screenshots, endpoint timeline, user identity records, cloud audit logs, and analyst notes. Every evidence item must include owner, collection time, source system, and hash when available.

Communication: The incident commander sends internal updates every thirty minutes for Severity 1 and every two hours for Severity 2. External communication requires legal approval. Do not tell affected users to delete messages, files, or browser history.

Recovery: Recovery begins only after containment is complete and evidence is preserved. The team validates that credentials are rotated, risky sessions are revoked, affected systems are patched, and monitoring rules are updated. A post-incident review must identify root cause, missed controls, action owners, and due dates.